

IIT Roorkee × Futureense

PG Certificate Program in AI/GenAI Powered Cybersecurity
Capstone Project — Cohort 1

CloudGuardian — AI-Driven Cloud Misconfiguration Detection and Remediation

Field	Detail
EC-Council Track	Cloud Security Essentials (CSE)
Project Code	CAP - CSE - 3W
Mode	Individual or Team (2–4 members)
Duration	3 weeks (~35–40 hours of effort)
Difficulty	Foundational → Intermediate (industry-aligned)
Delivery Mode	Hands-on lab + written report + oral defense
Program	PG Certificate in AI/GenAI Powered Cybersecurity, IIT Roorkee × Futureense

1. Project Overview

Students deploy a small workload in a free-tier cloud account, deliberately introduce a controlled set of misconfigurations, then build an automated detection-and-remediation pipeline. An ML/LLM layer prioritizes findings and drafts plain-English remediation guidance.

2. Real-World Problem Statement

A health-tech scale-up keeps failing ISO 27001 audits because the same misconfigurations reappear every sprint: public storage buckets, over-privileged IAM roles, unencrypted databases, missing logging. They need continuous CSPM (Cloud Security Posture Management) with safe auto-remediation for a small set of fixes and a risk-prioritized backlog for everything else.

3. Key Learning Outcomes

- Understand the shared-responsibility model and CIS Benchmarks for your chosen cloud.
- Run open-source CSPM tools and consolidate findings.
- Build a simple ML-based prioritization model.
- Use an LLM to generate plain-English remediation guidance (with disclosure and verification).
- Build event-driven auto-remediation with safety guardrails.

4. Tools and Technologies

Layer	Tools
Cloud	AWS Free Tier (default) or Azure free credits
IaC	Terraform
CSPM	Prowler (primary), ScoutSuite (cross-check), Steampipe (queries)
Native services	AWS Security Hub / Azure Defender (read-only mode)
Auto-remediation	AWS Lambda or Azure Functions
ML / LLM	Python, pandas, an LLM via API
Reporting	Markdown / PDF

5. Phased Plan — 3 Weeks

Week 1 — Build and Break (~12 hours)

1. Deploy a 3-tier reference workload via Terraform (VPC, two subnets, a web tier, a small RDS or SQL instance, an object-storage bucket).
2. Document the baseline posture using Prowler.
3. Introduce a controlled set of 10–12 misconfigurations across IAM, storage, networking, encryption, and logging.

Week 1 deliverable: Terraform code + baseline Prowler report + misconfig catalogue with rationale.

Week 2 — Detect and Prioritize (~14 hours)

1. Run all chosen CSPM tools; consolidate findings into a normalized schema (CSV/JSON).
2. Build a simple prioritization model: $CVSS \times exposure \times blast-radius \rightarrow priority\ score$.
3. Use the LLM to produce a 2-line plain-English explanation per finding. Verify the LLM's output against the raw scanner data.

Week 2 deliverable: Consolidated findings DB + prioritization notebook + LLM prompts and outputs (with verification notes).

Week 3 — Remediate and Govern (~12 hours)

1. Build automated remediations for at least three safe fixes (e.g., re-enable bucket public-access-block, rotate exposed IAM access keys, enable default encryption).
2. Implement a human-approval gate for remediations classified as risky.
3. Map controls to ISO 27001 Annex A and the DPDP Act 2023.
4. Write the final report and prepare the defense.

Week 3 deliverable: Remediation functions + compliance crosswalk + final report.

6. Final Deliverables

- Terraform code for the workload (in repo).
- Misconfiguration catalogue.
- Consolidated CSPM findings database.
- Prioritization model notebook + LLM prompt library.
- Auto-remediation functions with guardrails.
- Compliance crosswalk table.
- End-to-end demo recording (detect → prioritize → remediate).
- 12–15 page final report.

7. Evaluation Rubric

Criterion	Weight	What "Excellent" Looks Like
Workload design + IaC quality	15%	Reproducible Terraform, sensible architecture
Misconfig detection	15%	All 10+ misconfigs detected and consolidated
Prioritization model	15%	Justified features, honest evaluation
LLM remediation guidance	15%	Plain-English, verified against raw findings, not hallucinated
Auto-remediation + guardrails	15%	Safe defaults, human-approval gate for risky fixes
Compliance mapping	10%	Accurate ISO 27001 + DPDP references
Report + oral defense	15%	Tight, evidence-based
Total	100%	

8. Mode: Individual vs Team Scope

Aspect	Individual	Team (2–4)
Cloud providers	One (AWS or Azure)	Two
Misconfigurations introduced	8	12+
Auto-remediations	2	4
Compliance frameworks mapped	ISO 27001	ISO 27001 + DPDP + one of HIPAA/PCI-DSS
Report length	10–12 pages	14–18 pages

9. Estimated Duration

3 weeks, approximately 35–40 hours per learner.

10. Difficulty Level

Intermediate. Familiarity with at least one cloud provider is strongly recommended before starting.

11. Suggested Stretch Goals (Optional)

- Build a small Streamlit dashboard that lets a security engineer review and approve/reject LLM-suggested remediations.
- Ensure no IAM principal names leave the cloud account in plaintext when fed to the LLM (privacy-preserving redaction).

12. Ethics, Safety, and Responsible Use

- All offensive activity, scanning, or exploitation must be confined to the lab or instructor-provided sandbox. No real-world targets.
- Any use of GenAI / LLMs must be disclosed in the report (which model, what it was used for, how outputs were verified).
- Students must never paste real credentials, secrets, customer data, or copyrighted content into an LLM.
- All evidence and logs handled in the project remain confidential within the cohort.
- Students must sign the program's Responsible AI Use and Lab Conduct acknowledgement before starting Week 2.

13. References

- **EC-Council Essentials Series** — official module outlines and lab guides (provided via the program LMS).
- **MITRE ATT&CK** — <https://attack.mitre.org>
- **NIST Cybersecurity Framework 2.0** — <https://www.nist.gov/cyberframework>
- **OWASP Top 10 (Web / IoT / LLM)** — <https://owasp.org>
- **CIS Benchmarks** — <https://www.cisecurity.org/cis-benchmarks>
- **CERT-In advisories** — <https://www.cert-in.org.in>

Prepared by the Program Office, PG Certificate in AI/GenAI Powered Cybersecurity.

IIT Roorkee × Futureense — Cohort 1
